Lab 02

Defining Users and Roles

WSO2 API Manager 4.7.0 · Practical exercise

Before You Begin

URLs in this guide use placeholders. Replace them with the values of the API Manager you are using:

- **`<APIM_HOST>`** – host name or IP address of the API Manager server (localhost when API Manager runs on your own laptop).
- **`<HTTPS_PORT>`** – API Manager HTTPS port: 9443 plus any port offset (Publisher, Developer Portal, Admin Portal, Management Console, token endpoint).
- **`<GW_HTTPS_PORT>` / `<GW_HTTP_PORT>`** – API Gateway ports: 8243 (HTTPS) and 8280 (HTTP) plus any port offset.
- **`<APIM_HOME>`** – the folder where API Manager is extracted.

The servers use a self-signed certificate by default, so the browser shows a security warning the first time: choose Advanced and continue.

Training Objective

In this exercise you set up custom roles and users. Roles group permissions, so you can grant the same access to many users at once instead of to each user individually. In API Manager 4.7.0, access to the Publisher, Developer Portal and Admin Portal is controlled by OAuth2 scopes, so a custom role only works after it is mapped to one of the built-in Internal/* roles.

Business Scenario

PizzaShack has one employee who creates the menu, order and delivery APIs and another who publishes them to the website. API consumers log in to the Developer Portal to use these APIs. Separate roles and users are needed for API creators and API publishers, plus test users for consumers.

High-Level Steps

- Define roles in the Management Console
- Map the custom roles to internal roles in the Admin Portal (scope assignments)
- Define users in the Management Console and check what each user can do

Part 1 – Define Roles

1. Open a Command Line Interface.
2. Start WSO2 API Manager. Skip this step if it is already running.

   Linux / macOS

   ```
   cd <APIM_HOME>/bin
   sh api-manager.sh
   ```

CC BY 4.0

Example – Linux / macOS:

```
cd ~/wso2am-4.7.0/bin
sh api-manager.sh
```

Windows

```
cd <APIM_HOME>\bin
api-manager.bat --run
```

Example – Windows:

```
cd C:\wso2am-4.7.0\bin
api-manager.bat --run
```

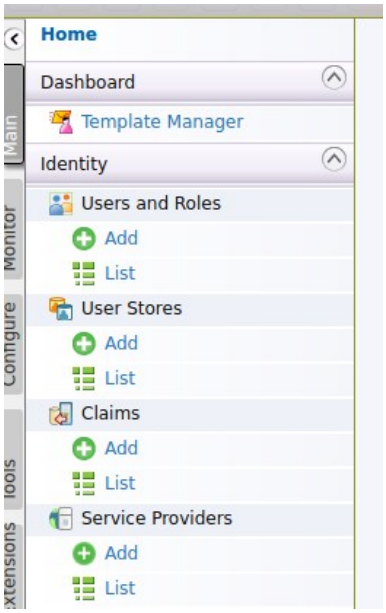
3. Log in to the Management Console with the admin account (default user name and password: **admin** / **admin**):

```
https://<APIM_HOST>:<HTTPS_PORT>/carbon
```

Example:

```
https://localhost:9443/carbon
```

Management Console menu: Main > Identity > Users and Roles



CC BY 4.0

4. Click **Main > Users and Roles > Add > Add New Role**.
5. Keep the domain as **PRIMARY** and enter **apicreator** as the role name.
6. Click **Finish**. You do not need to select permissions on the next page: portal access is given through the scope mapping in the next part.
7. Repeat steps 4 to 6 to create a second role named **apipublisher**.

Part 2 – Add Role Mapping

In API Manager 4.7.0, the Publisher, Developer Portal and Admin Portal call REST APIs, so access control is based on OAuth2 scopes. Each action in the portals needs a specific scope, and these scopes are mapped to the built-in **Internal/*** roles. For example, the `apim:api_create` scope is bound to **Internal/creator** and `apim:api_publish` to **Internal/publisher**.

To make the custom **apicreator** role behave like **Internal/creator** (and **apipublisher** like **Internal/publisher**), add a role mapping. The role must already exist in the Management Console, otherwise the mapping cannot be saved.

8. Log in to the Admin Portal as **admin** and go to **Settings > Scope Assignments**:

```
https://<APIM_HOST>:<HTTPS_PORT>/admin
```

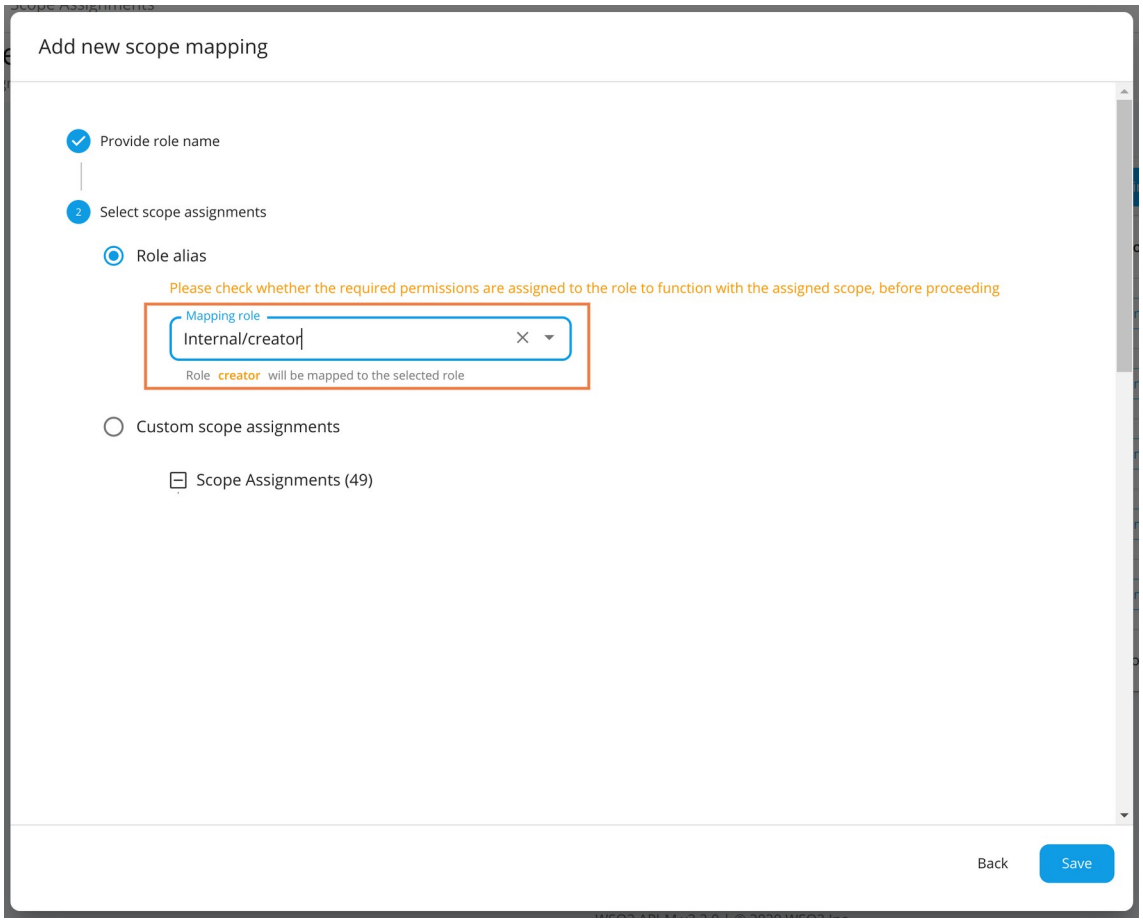
Example:

```
https://localhost:9443/admin
```

CC BY 4.0

9. Click **Add scope mappings**.

10. Enter **apicreator** as the **Role Name** and click **Next**. Select **Role alias** and choose **Internal/creator** as the **Mapping role**.



11. Click **Save** to add the scope-role mapping. The role now appears in the **Scope Assignments** list.

12. Repeat steps 9 to 11 for the **apipublisher** role: Role Name **apipublisher**, Mapping role **Internal/publisher**.

Part 3 – Define Users via the Management Console

Create one user for each role. Go back to the Management Console:

```
https://<APIM_HOST>:<HTTPS_PORT>/carbon
```

Example:

```
https://localhost:9443/carbon
```

CC BY 4.0

For each user in the table, do the following:

13. Click **Main > Users and Roles > Add > Add New User**.
14. Enter the user name and the password **password** (enter it twice).
15. Click **Next**, select the role from the table (for **mike** select no role), and click **Finish**.

User name	Password	Role
`creator`	`password`	apicreator
`publisher`	`password`	apipublisher
`subscriber`	`password`	Internal/subscriber
`mike`	`password`	none (do not assign any role)

Note: Instead of the custom role, you could also assign the built-in **Internal/creator** role to creator, which needs no scope mapping.

Part 4 – Check the Users

Optionally, open the Publisher in a private browser window and sign in as each user to see the difference:

```
https://<APIM_HOST>:<HTTPS_PORT>/publisher
```

Example:

```
https://localhost:9443/publisher
```

- **creator**: can create, edit and deploy APIs, but cannot publish them (only a user with the publisher role can change the API lifecycle).
- **publisher**: can publish APIs and create API Products, but cannot create new APIs.
- **subscriber**: cannot log in to the Publisher, but can log in to the Developer Portal (`https://<APIM_HOST>:<HTTPS_PORT>/devportal`).
- **mike**: has no roles. This user is used in the Invoking the API lab to show that a user without the right role cannot get the `order_pizza` scope.

Expected Outcome

Two custom roles (apicreator and apipublisher) have been created and mapped to Internal/creator and Internal/publisher. Users creator and publisher have the matching roles. The users subscriber (Internal/subscriber) and mike (no role) will be used to test the PizzaShack application.

CC BY 4.0